

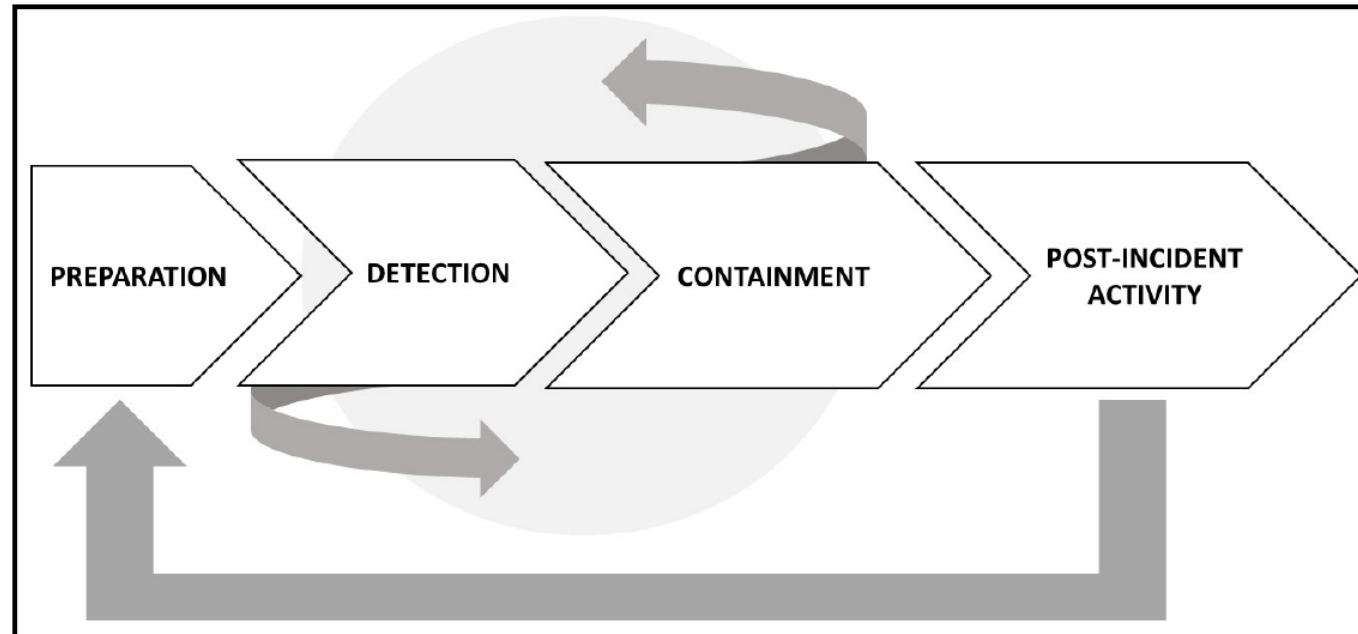
CSIT302 Cybersecurity



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

WannaCry (Case Study)

- EY Technical intelligence analysis — WannaCry attack, ([https://www.ey.com/Publication/vwLUAssets/ey-wannacry-ransomware-attack/\\$File/ey-wannacry-ransomware-attack.pdf](https://www.ey.com/Publication/vwLUAssets/ey-wannacry-ransomware-attack/$File/ey-wannacry-ransomware-attack.pdf))



WannaCry

- Introduction

- On 12 May 2017, a massive ransomware attack occurred across a wide range of sectors, including health care, government, telecommunications and gas. To date, WannaCry has spread to over 300,000 systems in over 150 countries.

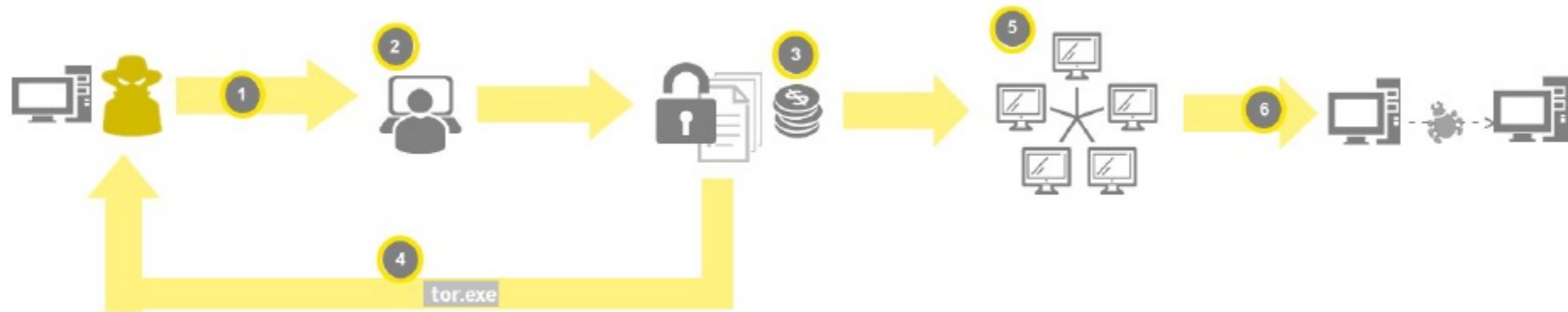
- 30–40 publicly named companies were infected: the Russian Interior Ministry, Telefonica (Spain's largest telecommunications company) and FedEx



WannaCry

- How it works

- WannaCry is a type of ransomware that encrypts files, disks and locks computers.
- WannaCry spreads via the Server Message Block (SMB) protocol operating over ports 445 and 139, typically used by Windows machines to communicate with file systems over a network.



WannaCry

- How it works

1. Attacker uses a yet-to-be-confirmed initial attack vector
2. WannaCry encrypts files in the victim's machine using AES-128 cipher, deletes shadow copies.
3. It then displays a ransom note requesting \$300 or \$600 in bitcoin
4. Tor.exe is used by wannadecryptor.exe, initiating connections to tor nodes in order to connect back to the attacker (therefore making this extremely difficult, if not impossible, to track)
5. IP address of the infected machine is checked; then IP addresses of the same subnet are scanned for additional vulnerable machines and connected to via port 445 TCP
6. When a machine is successfully connected, data containing the exploit payload is transferred

WannaCry

- How it works
 - WannaCry utilizes the exploit **Eternal Blue**, created by NSA and released by Shadow Brokers on 14 April 2017. Of note, the malware also checks for existing backdoors via **Double Pulsar**, also released by Shadow Brokers, in order to help propagate through client networks.



WannaCry

- **ETERNALBLUE: (CVE-2017-044)**

- This is an exploit that is believed to have been created by NSA and released publically by Shadow Brokers on 14 April. Microsoft released a patch for this vulnerability on 14 March 2017.
- The vulnerability exists because the SMB version 1 (SMBv1) server in various versions of Microsoft Windows mishandles specially crafted packets from remote attackers, allowing them to execute arbitrary code on the target computer.

- **DOUBLEPULSAR:**

- This is not an exploit; it is an implant that would be delivered via some exploit. The implant then allows for delivery of a malicious DLL from a remote system and then injects that DLL into memory on the compromised system. Think of an implant as a specialized backdoor. As such, there is no patch for DOUBLEPULSAR, just the exploits that were used to deliver it.

WannaCry

- Indicator of compromise (IOCs) for WannaCry
 - Hashes: ed01ebfbc9eb5bbea545af4d...
 - URLs: <http://146.0.32.144:9001>, <http://188.166.23.127:443>, ...
 - IPs: 91.121.65.179, 89.40.71.149, ...
 - File names: wcry.exe, WanAcry.exe, wanacry.exe ...
 - Targeted extensions: .der, .pfx, .key, .crt, .csr, .p12, .pem ...

WannaCry

- Containment

- The researcher obtained a copy of the malware, which he analyzed and discovered a reference to an unregistered domain called www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com.
- They registered this domain and inadvertently paused the spread of the worm-like attack. This is because WannaCry attempts to connect to the web domain.
- If it cannot do so, it will proceed with the infection — however, if it does connect, the malware will cease the attack, believing it is being run in an antivirus “sandbox” environment.
- The registration of the website triggered the malware’s kill switch.

WannaCry

- Containment

- If you notice the screen shown in the figure, which is in page 6 in our slide, on your computer or change to the file extensions of important files to one of those specified at the end of this advisory, then you are possibly a victim of this ransomware. Following the steps below immediately can help to reduce the impact.

- ✓ Disconnect all network connections and external storage immediately
 - ✓ Shut down the computer and inform your IT teams
 - ✓ Do not pay any ransom to the hacker, as this fuels the illegal ecosystem and there is no guarantee that you will get the data back
 - ✓ Safeguard and keep your backups ready before experts assist you

WannaCry

- Containment

- ***Company-level recommendations:***

- ✓ Block SMB port access and RDP (Remote Desktop Protocol) to all computers from the internet; Port 445 and 139 for SMB and 3389 for RDP should be blocked
 - ✓ Block SMB for the time being within the company through a group policy or other endpoint security solution
 - ✓ Stop granting any privilege escalation requests to users who want to run an unknown program as an administrator
 - ✓ Maintain backups that account for critical data and the rate of data generation
 - ✓ Endpoint monitoring, Email filtering, Security awareness training and more

WannaCry

- Containment

- ***Employee recommendations:***

- ✓ Disconnect from the internet and take a backup of all your data on an encrypted, removable hard drive; disconnect the hard drive and keep it at a secure location after the backup is completed
 - ✓ Do not open attachments from unknown sources, and do not download or open unauthorized software.
 - ✓ And more

WannaCry

- Containment

- ***IT administrator recommendations:***

- ✓ Disconnect all network shares from idle computers and servers
 - ✓ Recheck network shares with write permissions
 - ✓ Change passwords of and safeguard all common domain administrator accounts; refrain from logging in using these accounts; and use these accounts to only authorize specific actions as per standard operating procedures.
 - ✓ And more

Risk mitigation consideration (Lesson Learned)

- Organizations can help mitigate their risk exposure by considering the following actions:
 - Ensure that vulnerability management (including patch management and vulnerability scanning/remediation) is a robust and mature enterprise-level program
 - Maintain backups that account for critical data and the rate of data generation
 - ✓ Align timeline and procedures for restoring system backups with your business continuity plan (BCP)
 - ✓ Review the organization's incident response and disaster preparedness plans to verify that they adequately address recovery from a ransomware event

Risk mitigation consideration (Lesson Learned)

- Implement endpoint monitoring, giving teams visibility into malicious behaviour occurring at that level
- Ensure that the organization has a comprehensive security awareness training program in place
- Maintain an effective enterprise **incident response plan** that is regularly tested and measured for effectiveness against ransomware, as well as regularly updated to reflect the current cyber threat environment
- Confirm that critical systems are not unnecessarily connected to/accessible from the internet